

Guía para evaluar riesgos

NIST SP 800-30 es una publicación que ofrece orientación sobre la realización de evaluaciones de riesgos. Describe estrategias para identificar, analizar y remediar riesgos. Las organizaciones utilizan el NIST SP 800-30 para obtener información sobre la probabilidad y gravedad potencial de los riesgos, ayudándoles a tomar decisiones informadas sobre la asignación de recursos, la implementación de controles y la priorización de los esfuerzos de remediación.

Este documento de cuatro páginas está adaptado del NIST SP 800-30 Rev. 1. El término "Rev. 1" indica que es la primera versión actualizada de esta publicación. El NIST ocasionalmente revisa sus documentos para incorporar nueva información, reflejar cambios en la tecnología y los requisitos regulatorios, o abordar la retroalimentación.

Nota: El Centro de Recursos de Seguridad Informática [del NIST](#) contiene más información sobre el SP 800-30 Rev. 1.

Fuentes de amenaza

El NIST SP 800-30 define y categoriza las fuentes de amenaza como entidades o circunstancias que pueden afectar negativamente a los sistemas de información de una organización. Esta información es útil para identificar y evaluar posibles riesgos. Al referenciarlo, considera la intención o capacidades de las fuentes de amenaza internas y externas.

Nota: La siguiente tabla enumera algunas posibles *fuentes de amenazas* que podrían comprometer un servidor de base de datos accesible públicamente.

Tipo	Ejemplos	Descripción
Humano	<i>Usuario estándar</i> Empleado Cliente <i>Usuario privilegiado</i> Administrador de sistemas <i>Grupo</i> <i>Competidor</i> Proveedor Socio comercial Estado nación <i>Forastero</i>	Amenazas derivadas de individuos o grupos que podrían explotar intencionada o accidentalmente los recursos cibernéticos. Por ejemplo, podrían alterar los datos de una manera que afecte negativamente a la empresa. Alternativamente, podrían robar datos intencionadamente y dañar el equipo empresarial.

	Hacker Hacktivista Amenaza persistente avanzada (APT)	
Tecnológico	Hardware Almacenamiento Procesamiento Comunicaciones Software Sistema(s) operativo(s) Networking Software malicioso	Amenazas que provienen de factores no humanos. Por ejemplo, fallos de equipos debido al envejecimiento, agotamiento de recursos u otras circunstancias.
Medio	Entorno operativo Controles de temperatura Controles de humedad Fuentes de alimentación defectuosas Peligros naturales Cortes de luz Fenómenos meteorológicos extremos	Amenazas que surgen de factores accidentales y no humanos. Por ejemplo, fallos de equipos causados por el entorno operativo.

Eventos de amenaza

El NIST SP 800-30 define y categoriza los eventos de amenaza como casos reales en los que una fuente de amenaza explota una vulnerabilidad y causa daños o perjuicios a los sistemas de información de una organización. Esta información es útil para obtener información sobre los tipos de riesgos a los que se enfrentan los activos. Se pueden identificar controles y contramedidas más efectivos comprendiendo posibles eventos de amenaza,

Nota: La siguiente tabla enumera solo algunos posibles *eventos de amenaza* que podrían comprometer un servidor de base de datos de acceso público.

Ejemplos	Descripción
Realizar reconocimiento y vigilancia de la organización	La fuente de amenazas examina y evalúa las vulnerabilidades de la empresa a lo largo del tiempo utilizando diversas herramientas (por ejemplo, escaneo, observación física).

Obtener información sensible mediante exfiltración	La fuente de amenazas instala software malicioso en los sistemas de la organización para localizar y adquirir información sensible.
Alterar/Eliminar información crítica	La fuente de amenazas altera o elimina datos que son críticos para las operaciones diarias del negocio.
Certificados de fabricación falsos.	La fuente de amenaza compromete a una autoridad certificadora para que sus conexiones parezcan legítimas.
Instalar detectores de red persistentes y dirigidos en los sistemas de información de la organización.	Threat source instala software diseñado para recoger (detectar) tráfico de red durante un periodo de tiempo continuo.
Realizar ataques de denegación de servicio (DoS).	La fuente de amenazas envía solicitudes automáticas y excesivas para saturar las capacidades operativas del sistema.
Interrumpir operaciones críticas para la misión.	La fuente de amenazas compromete la integridad de la información de tal manera que impide que la empresa realice operaciones críticas.
Ocultar futuros ataques.	La fuente de amenazas toma medidas para inhibir la eficacia de los sistemas de detección de intrusiones o de las capacidades de auditoría de la empresa.
Realizar ataques de "hombre en medio".	La fuente de amenazas escucha sesiones entre sistemas internos y externos. Más tarde, transmiten mensajes entre sistemas organizativos y externos que les hacen creer que están hablando directamente entre sí a través de una conexión privada.

Probabilidad de un evento de amenaza

En general, la *probabilidad* de un evento de amenaza debe ser una puntuación basada en una combinación de factores. Por ejemplo, cualquier evidencia disponible que tengas, experiencia previa y tu juicio experto.

Considera la intención y capacidades de una fuente de amenaza y los posibles eventos de amenaza al producir una puntuación de probabilidad.

Valores cualitativos	Valores cuantitativos	Descripción
Alto	3	La fuente de amenazas casi con toda seguridad iniciará un evento de seguridad. Un evento podría tener efectos múltiples, graves o catastróficos en las operaciones y activos empresariales.
Moderado	2	La fuente de amenaza es algo probable que inicie un evento de seguridad. Un evento podría reducir significativamente la funcionalidad de las operaciones y activos organizativos.
Bajo	1	La fuente de amenaza es muy poco probable que inicie un evento de seguridad. Un evento podría tener efectos menores e insignificantes en las operaciones y activos del negocio.

Gravedad de un evento de amenaza

En general, la *gravedad* de un evento de amenaza es una medida de su posible impacto en las operaciones empresariales. Por ejemplo, ¿el evento haría que una función empresarial se detuviera por completo? ¿Podría interrumpir temporalmente un proceso empresarial y pasar desapercibido?

Considere el impacto empresarial de *los eventos de amenaza* al elaborar una puntuación de gravedad.

Valores cualitativos	Valores cuantitativos	Descripción
Alto	3	La fuente de amenazas casi con toda seguridad iniciará un evento de seguridad. Un evento podría tener efectos múltiples, graves o catastróficos en las operaciones y activos empresariales.
Moderado	2	La fuente de amenaza es algo probable que inicie un evento de seguridad. Un evento podría reducir significativamente la funcionalidad de las operaciones y activos organizativos.
Bajo	1	La fuente de amenaza es muy poco probable que inicie un evento de seguridad. Un evento podría tener efectos menores e insignificantes en las operaciones y activos del negocio.